13.3 Revisão de RLS ponta a ponta — status de entrega

Bloco 13.3 Revisão de RLS ponta a ponta · Sprint 13 — Administração, qualidade e segurança · Data: 2026-10-07 · Branch: `main` · Ambiente: gc-dev (`gzbmhgnpoehormnidmgg`)

Resumo

Validado: a rodada do bloco (`caffeinate -ims npm run validar` , 2026-10-10, com o Mac na tomada) passa nas sete camadas. Números na seção 4.

A revisão achou **seis pontos frouxos**, todos provados em gc-dev antes da correção (seção 2). Nos seis, a tela barrava e o banco ou a rota não. Também achou uma **regressão de desempenho** ligada à RLS, que fazia a importação de 500 itens estourar o tempo limite (seção 2b). A regra de acesso agora está escrita num arquivo só, `scripts/validacao/matriz-rls.json` , e a camada de validação confere cada célula dela a cada rodada. São 456 células de tabela, 108 de bucket e 342 de rota.

1. As seis atividades do bloco

ATIVIDADE DO CLICKUP	ONDE FICOU
Matriz perfil × entidade × operação (CRUD) documentada	`scripts/validacao/matriz-rls.json` , lido pela validação; a tradução para leitura está na seção 3
Testar cada célula da matriz com um usuário real de cada perfil	`scripts/validacao/matriz-rls.mjs` , na camada **dados**. Tabelas: o SQL assume o papel `authenticated` com o usuário de cada perfil, exatamente o que o PostgREST faz com o JWT. Cada insert, update e delete roda de verdade (com trigger e policy) numa subtransação desfeita. Buckets: a API de Storage com a sessão de cada perfil
Testar bypass por URL direta em todas as rotas	Varredura na camada **runtime**: cada rota de `rotas-esperadas.txt` × os seis perfis, contra o mapa `rotas` da matriz. Quem pode recebe 200; quem não pode é redirecionado (página) ou recebe 401/403 (API)
Testar bypass por chamada direta à API do Supabase	A matriz de tabelas é a chamada direta, com a sessão de cada perfil. Sem sessão, uma checagem nova na camada dados confere que a chave pública não lê nenhuma tabela e não chama as RPCs revogadas
Conferir RLS dos 4 buckets de Storage	São **cinco** com policy (`anexos` , `documentos` , `documentos-processamento` , `evidencias` , `notas-fiscais`), mais o comprovante de pagamento dentro de `anexos` como célula própria. Há um sexto bucket, `teste-automacao-ocr` , sem policy nenhuma (seção 4)

ATIVIDADE DO CLICKUP	ONDE FICOU
Corrigir as policies que estiverem frouxas	Migrations `20261007100000_rls_revisao_13_3.sql` e `20261007110000_rls_comprovante_upload.sql`, aplicadas em gc-dev, e guarda de perfil em duas rotas de API (seção 2)

2. Os pontos frouxos e a correção

#	ACHADO	PROVA ANTES	CORREÇÃO
1	`atualizar_status_nf_by_id` e `atualizar_status_parcela_by_id` são `SECURITY DEFINER`, recebem um id e estavam liberadas para **anon** por `/rpc`. Com a chave pública, qualquer um recalculava e gravava o status de NF e parcela de **qualquer empresa**	`anon.rpc('atualizar_status_nf_by_id', …)` executou	`revoke` de `public`, `anon` e `authenticated`. Quem chama são os triggers de pagamento, NF e parcela, que também são `SECURITY DEFINER` e não dependem desse grant (a camada escrita, com os testes de pagamento, passa)
2	NF, pagamento, FD, acordo e parcela tinham select **para todos os perfis da empresa**. Produção e medição não entram em `/financeiro` nem em `/fd`, mas liam tudo pela API	Produção e medição liam 8 NFs, 9 pagamentos, 5 FDs, 5 acordos e 10 parcelas	Select por perfil. NF, pagamento, acordo e parcela: admin, financeiro, visualizador e **comercial**, que lê o faturado e o recebido na proposta e no contrato pelas views `security_invoker`. FD: admin, financeiro e visualizador. Depois da correção, produção e medição leem 0
3	Bucket `notas-fiscais`: qualquer perfil lia o XML e o PDF	Policy de select sem perfil (o bucket está vazio em gc-dev, então a listagem não mostrava arquivo)	Select de admin, financeiro e visualizador, os perfis que geram o link assinado na tela da NF
4	Comprovante de pagamento (`anexos/<empresa>/<x>/pagamentos/`): leitura aberta à empresa toda	Policy de select sem perfil	A pasta segue a tabela `pagamentos` na leitura; o resto do bucket não muda
5	O mesmo comprovante: **produção, medição e comercial enviavam arquivo** para a pasta que a aba de pagamentos lê	Achado pela própria matriz, com 3 divergências na primeira rodada	Envio para a pasta `pagamentos` só por admin e financeiro (migration `20261007110000`)
6	`/api/export/fd` e `/api/relatorio/fd-conciliacao/[obraId]` **não conferiam o perfil**: a URL direta respondia 200 a qualquer um	Leitura das rotas; as outras exportações têm a guarda	`PERFIS_COM_ACESSO = ['admin', 'financeiro', 'visualizador']`, com 403 como nas demais

2b. A regressão do recálculo do valor (desempenho, RLS)

A primeira rodada do bloco parou na camada escrita, duas vezes seguidas, no passo "500 linhas entram numa importação só", com `canceling statement due to statement timeout`. Medido no banco, numa transação desfeita, o insert de 500 itens como admin levou **6,1 s**. Sem o trigger `recalcular_valor_do_pai_do_item`, levou 0,2 s; como dono da tabela, sem RLS, 0,4 s.

A causa vem da sprint 8. A migration 017 (`20260922140000`) tinha posto esse trigger como `security definer`, porque como `security invoker` a soma que ele faz a cada item passa pela policy de `itens` e chama `current_empresa_id()` para cada linha somada. São cerca de 125 mil chamadas para 500 itens. A 031 (`20260928100000`, a do deadlock) recriou a função copiando o corpo de uma migration anterior à 017 e voltou a `security invoker` sem querer: o cabeçalho dela diz que só a palavra da trava mudava. O 13.1 deixou cada chamada mais cara, porque as funções das policies passaram a olhar `ativo`, e o passo, que já andava perto de 8 s, passou do limite.

Correção: migration `20261007120000_recalculo_valor_definer_de_volta.sql`, aplicada em gc-dev. Ela devolve `security definer` (o corpo é o da 031, com a trava sem deadlock) e revoga a execução da função para os papéis da API. O mesmo insert caiu para **0,45 s**. A justificativa de segurança da 017 continua valendo: o trigger só dispara depois que a RLS autorizou o item, e só escreve a soma no pai do mesmo item.

2c. Filtros que esticavam a página no celular

A camada navegador da rodada 4 reprovou em três checagens de 390 px (`/propostas`, `/contratos` e a visão geral rolavam 11 px de lado). Não veio deste bloco: uma obra nova em gc-dev, "BRA-2026-005 — Residencial Vista Verde - Bloco B", criada às 22:02 pela trilha da automação, tem o nome mais longo do cadastro. O `<select>` de obra dos filtros cresce até a opção mais longa e, na coluna do celular, empurrava a página. O bug já existia e esperava um nome comprido para aparecer.

Correção: `max-w-full` nos 24 selects dos filtros das listagens (`*/filters.tsx`) e no contêiner dos filtros da visão geral, que fica numa linha flex ao lado do título. Medido pela skill `run-gc-sistema` em 390 px depois da correção, as 12 listagens têm exatamente 390 px.

Também desligado: o **cadastro aberto** do Auth do gc-dev (`disable_signup = true`, achado do 13.1). `POST /auth/v1/signup` com a chave pública responde agora `signup_disabled`. O convite do 13.1 não é afetado, porque usa a API de administração (a camada escrita passa com os 20 passos do 13.1).

O que não mudou e está certo assim: todas as tabelas têm RLS ligada. As seis views são `security_invoker`. Visualizador não escreve em lugar nenhum. As policies de update sem `with check` usam o `using` como check, que é o comportamento do Postgres. Os triggers (`returns trigger`) não são chamáveis por `/rpc`.

3. A matriz (o que cada perfil pode)

Abreviações: adm, com (comercial), fin (financeiro), med (medição), prod (produção) e vis (visualizador). "Ler" na tabela é ver a linha da própria empresa. A fonte é `matriz-rls.json`; este texto é a leitura dela em 2026-10-07.

TABELA	LER	CRIAR	EDITAR	EXCLUIR
`clientes`	todos	adm, com	adm, com	adm
`contatos_whatsapp`	todos	adm, com	adm, com	adm
`orcamentos`	todos	adm, com	adm, com	adm
`obras`	todos	adm, com	adm, com	adm
`propostas`	todos	adm, com	adm, com	adm
`itens`	todos	adm, com	adm, com	adm
`contratos`	todos	adm, com	adm, com	adm
`documentos_processamento`	todos	adm, com	adm, com	adm
`execucao`	todos	adm, med, prod	adm, med, prod	adm
`execucao_medicoes`	todos	—	—	—
`notas_fiscais`	adm, com, fin, vis	adm, fin	adm, fin	adm
`pagamentos`	adm, com, fin, vis	adm, fin	adm, fin	adm, fin
`acordos_pagamento`	adm, com, fin, vis	adm, fin	adm, fin	adm, fin
`acordo_parcelas`	adm, com, fin, vis	adm, fin	adm, fin	adm, fin
`fd`	adm, fin, vis	adm, fin	adm, fin	adm, fin
`empresas`	todos	—	adm	—
`profiles`	todos	adm	adm, med	adm
`auditoria_eventos`	adm	—	—	—
`automacao_eventos`	todos	—	—	—

BUCKET	LER	ENVIAR	APAGAR
`anexos`	todos	adm, com, fin, med, prod	adm
`anexos/pagamentos`	adm, com, fin, vis	adm, fin	adm, fin
`documentos`	todos	adm, com	adm
`documentos-processamento`	todos	adm, com	adm
`evidencias`	todos	adm, fin, med, prod	adm
`notas-fiscais`	adm, fin, vis	adm, fin	adm

ROTA (URL DIRETA)	ABRE PARA
`/`	todos
`/obras`	todos
`/obras/[id]`	todos
`/obras/nova`	adm, com
`/obras/[id]/editar`	adm, com
`/clientes`	adm, com, vis
`/clientes/novo`	adm, com
`/clientes/[id]/editar`	adm, com
`/orcamentos`	adm, com, vis
`/orcamentos/[id]`	adm, com, vis
`/orcamentos/novo`	adm, com
`/orcamentos/[id]/editar`	adm, com
`/propostas`	adm, com, vis
`/propostas/[id]`	adm, com, vis
`/propostas/nova`	adm, com
`/propostas/[id]/editar`	adm, com
`/propostas/[id]/gerar-contrato`	adm, com
`/contratos`	adm, com, vis
`/contratos/[id]`	adm, com, vis
`/contratos/novo`	adm, com
`/contratos/[id]/editar`	adm, com
`/documentos`	adm, com, vis
`/documentos/[id]`	adm, com, vis
`/documentos/log`	adm, com, vis
`/execucao`	adm, med, prod, vis
`/fd`	adm, fin, vis

ROTA (URL DIRETA)	ABRE PARA
`/fd/[id]`	adm, fin, vis
`/fd/novo`	adm, fin
`/fd/[id]/editar`	adm, fin
`/financeiro`	adm, fin, vis
`/financeiro/visao-geral`	adm, fin, vis
`/financeiro/notas-fiscais`	adm, fin, vis
`/financeiro/notas-fiscais/[id]`	adm, fin, vis
`/financeiro/notas-fiscais/novo`	adm, fin
`/financeiro/notas-fiscais/[id]/editar`	adm, fin
`/financeiro/pagamentos`	adm, fin, vis
`/financeiro/pagamentos/novo`	adm, fin
`/financeiro/acordos`	adm, fin, vis
`/financeiro/acordos/[id]`	adm, fin, vis
`/financeiro/acordos/novo`	adm, fin
`/logs`	adm
`/configuracoes`	adm
`/configuracoes/contatos`	adm
`/configuracoes/usuarios`	adm
`/api/export/obras`	todos
`/api/template/itens`	todos
`/api/export/orcamentos`	adm, com, vis
`/api/export/propostas`	adm, com, vis
`/api/export/contratos`	adm, com, vis
`/api/export/execucao`	adm, med, prod, vis
`/api/export/notas-fiscais`	adm, fin, vis
`/api/export/pagamentos`	adm, fin, vis

ROTA (URL DIRETA)	ABRE PARA
`/api/export/acordos`	adm, fin, vis
`/api/export/financeiro`	adm, fin, vis
`/api/export/fd`	adm, fin, vis
`/api/relatorio/fd-conciliacao/[obraId]`	adm, fin, vis
`/api/relatorio/medicao/[obraId]`	adm, fin, med

Notas da matriz:

- `profiles`: a linha de amostra é a do usuário de medição. Por isso medição aparece em "Editar": ele edita a própria linha, e o trigger do 13.1 trava perfil, situação e e-mail.
- `auditoria_eventos`: a amostra é um evento fora de NF. O histórico da NF abre para financeiro e visualizador (13.2).
- `execucao_medicoes`, `auditoria_eventos` e `automacao_eventos` não têm escrita por sessão: quem grava são os triggers e a RPC.
- Fora da varredura de rotas ficam as públicas e as de token: `/login`, `/convite`, `/convite/senha`, `/sair`, `/_not-found` e as três `/api/ingestao/*`, que conferem `x-ingestao-token`.

4. Validação

Rodada final (rodada 7, `caffeinate -ims npm run validar`, 2026-10-10):

CAMADA	RESULTADO	DO 13.3
sobras	nenhuma em gc-dev	—
estático	**limpo** (`tsc` + `next lint`)	—
unitário	**393 casos**	nenhum novo (o bloco é policy e plano de validação)
build	**65 rotas**, iguais à baseline	nenhuma rota nova. A 65ª, `/api/ingestao/resposta-obra`, é da trilha da automação
runtime	**298/298 rotas** e **342 células** na varredura de URL direta, nenhuma rota furada	a varredura inteira: 57 rotas × 6 perfis
dados	**60/60 checagens**	**2 checagens**: a matriz (456 células de tabela e 108 de bucket, todas iguais a `matriz-rls.json`) e anon sem leitura nem RPC
escrita	**505/505 passos**	nenhum passo novo. Ela prova que os triggers de pagamento seguem funcionando sem o grant das RPCs revogadas, e a importação de 500 itens levou **1,7 s** (antes de 8 a 9 s, com timeout)

CAMADA	RESULTADO	DO 13.3
navegador	**256/256 passos**	as checagens de 390 px passam com a correção da seção 2c

Rodadas do bloco:

1. Parou na escrita: timeout na importação de 500 itens.
2. Parou no mesmo passo. A medição levou ao achado da seção 2b. A rodada foi interrompida para aplicar a correção, e as sobras dela foram apagadas.
3. Parou em dados: 1 célula de bucket (`anexos.select` como produção) falhou uma vez e passou nas duas execuções seguintes da matriz. A matriz passou a registrar a mensagem do erro e a repetir só erro de rede, nunca recusa da policy.
4. Seis camadas passaram (a tabela acima); o navegador parou nas 3 checagens de 390 px (seção 2c).
5. e 6. **Não terminaram.** O Mac estava na bateria e dormiu logo depois do início. O build levou 1 hora e o runtime ficou 43 horas parado. Na rodada 6, as sessões venceram durante o sono e as rotas responderam 307. Não é falha de código. As sobras dessas rodadas foram apagadas e o gc-dev está limpo.
6. **Final**, com o Mac na tomada: as sete camadas passam com os números da tabela.

5. Pendências

- **Bucket** `teste-automacao-ocr`: existe em gc-dev, não é público e não tem policy. Ninguém acessa pela API, só a chave de serviço. Parece sobra de teste da automação; apagar ou não é decisão do Breno.
- **Update de arquivo nos buckets** não está na matriz. As policies de update são "só o dono do arquivo" (`owner = auth.uid()`) ou por perfil, e o app não faz update de arquivo, só envio e exclusão.
- **Conferência visual**: o bloco não muda tela. Só as duas rotas de FD passam a responder 403 a quem não é do financeiro.

Registro para quem for operar gc-prod

Migrations pendentes, nesta ordem, depois das do 13.1 e do 13.2: `20261007100000_rls_revisao_13_3.sql`, `20261007110000_rls_comprovante_upload.sql` e `20261007120000_recalculo_valor_definer_de_volta.sql`. Em gc-dev, a última entrou com `db push --include-all`, porque a `20261008100000` (trilha da automação) já estava aplicada. Elas trocam policies e revogam dois grants, sem mexer em dado. Os achados 1 e 2 **existem em gc-prod** (as policies vêm da migration inicial). O cadastro aberto também deve ser desligado lá (`disable_signup`), que é configuração do projeto, não migration.